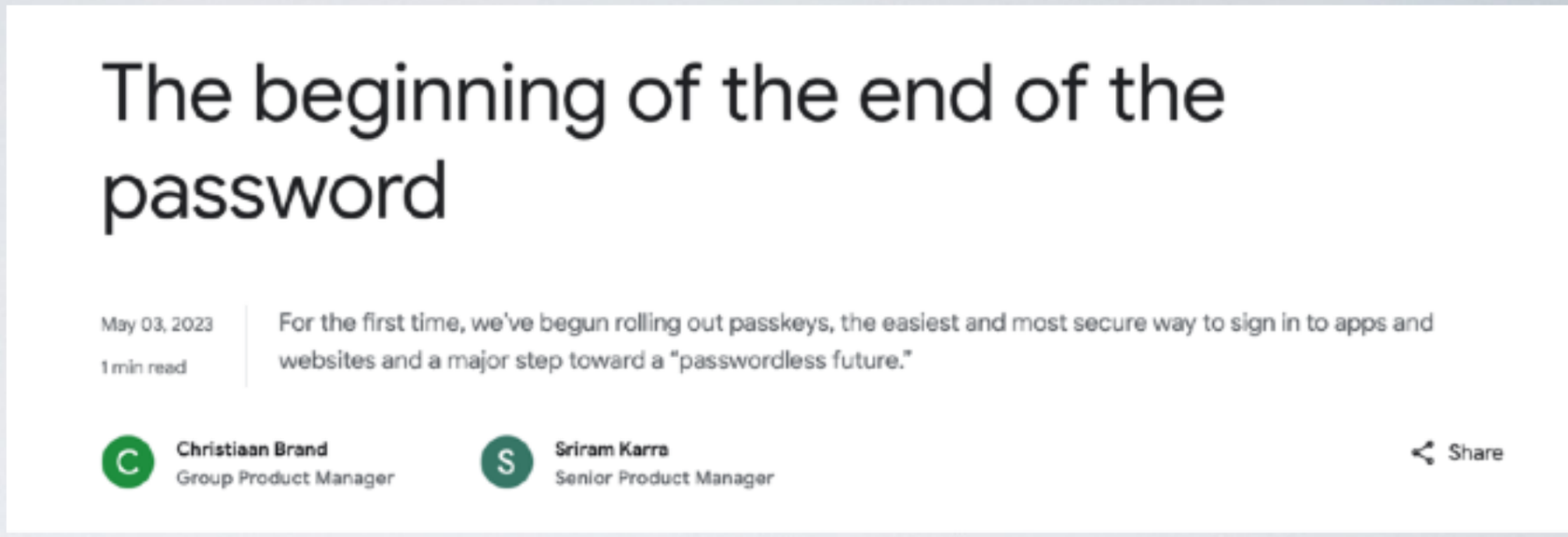
WebAuthn



The beginning of the end of the password

May 03, 2023

1 min read

For the first time, we've begun rolling out passkeys, the easiest and most secure way to sign in to apps and websites and a major step toward a "passwordless future."

Christiaan Brand
Group Product Manager

Sriram Karra
Senior Product Manager

Share

➡ Also called FIDO2 standard or **Passkeys**

Registration: The device generates a key pair and sends it to the service

Authentication: the service sends a challenge to the device that will returned it signed with the private key

✓ The device stores the private key inside **a safe storage** (e.g. keychain, password manager, Trusted Computing Module - TPM, USB Security Key) that comes with its own local authentication (e.g. master password, fingerprints, face recognition)

The weakest link : Account Recovery

What happen when users

- forget their login and/or password
- lose their devices
  with its stored TOTP secrets and/or passkeys

Account recovery can be implemented:

- using an email address (that can also be compromised)
- using another device (that can also be lost)
- using a seed passphrase to derive a private key directly (that can also be lost)

- Account recovery hijacking is often another attack vector